K8S Security Incident Response Architecture

- **Subtitle**: Event-driven security detection and policy enforcement architecture for Kubernetes workloads and RBAC risks
- **Tech Stack**: Kubernetes · RBAC · NetworkPolicy · Pod Security Admission · Trivy · GitHub Actions · Docker · Kind
- **Name**: SeokHyun Yoo
- **Role**: Cloud Security / Incident Response
- **Keywords**: Kubernetes IR · Container Security · RBAC Risk Detection · DevSecOps Security Automation · Policy-based Enforcement

Problem Definition

Kubernetes misconfigurations are one of the most critical causes of container security breaches.

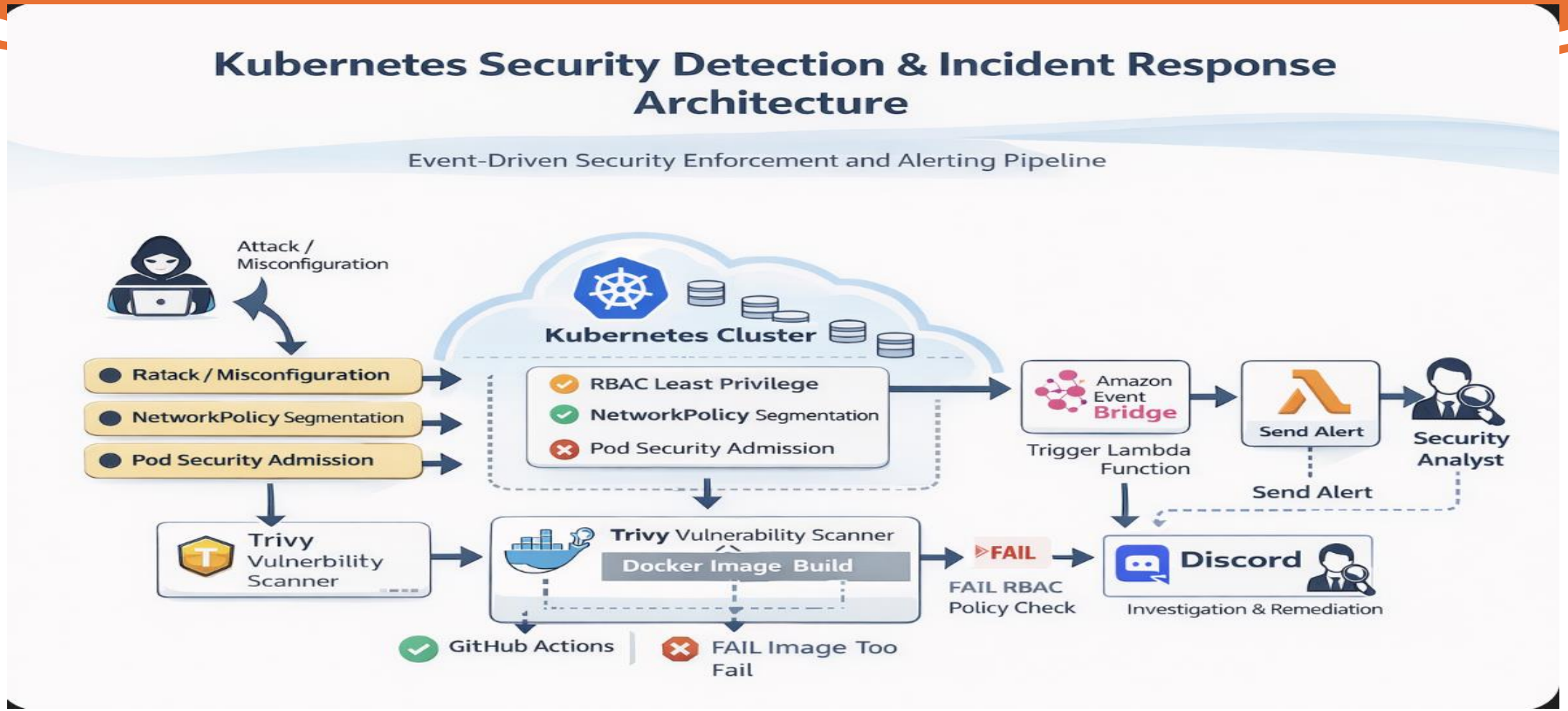
Over-privileged RBAC roles, insecure network communication between namespaces, and vulnerable container images

can allow attackers to escalate privileges, move laterally, or compromise cluster workloads.

Operational Gaps

- Over-privileged RBAC roles are often deployed without validation
- Cross-namespace network access increases lateral movement risk
- Privileged containers may bypass workload isolation controls
- Vulnerable container images are pushed into CI/CD pipelines
- Security detection and response are not automated in many environments

Architecture



RBAC Least Privilege Verification

Resource setting

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir kubernetes-security-automation-architecture % kubectl get ns

NAME              STATUS   AGE
default           Active   38m
dev               Active   28m
kube-node-lease   Active   38m
kube-public       Active   38m
kube-system       Active   38m
local-path-storage   Active   38m
prod              Active   28m
yuseoghyeon@yuseoghyeon-ui-MacBookAir kubernetes-security-automation-architecture % kubectl get pods -n dev

NAME                               READY   STATUS    RESTARTS   AGE
nginx-deployment-59f86b59ff-4dbqm   1/1     Running   0          19m
nginx-deployment-59f86b59ff-8hfw6   1/1     Running   0          19m
yuseoghyeon@yuseoghyeon-ui-MacBookAir kubernetes-security-automation-architecture % kubectl get pods -n prod

NAME             READY   STATUS    RESTARTS   AGE
privileged-test  1/1     Running   0          18m
yuseoghyeon@yuseoghyeon-ui-MacBookAir kubernetes-security-automation-architecture % kubectl get svc -n dev

NAME           TYPE       CLUSTER-IP    EXTERNAL-IP   PORT(S)   AGE
nginx-service  ClusterIP  10.96.30.53   <none>        80/TCP    19m
```

RBAC auth check

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl auth can-i get pods -n dev --as=system:serviceaccount:dev:dev-readonly-sa

yes
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl auth can-i list services -n dev --as=system:serviceaccount:dev:dev-readonly-sa
yes
```

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl auth can-i create pods -n dev --as=system:serviceaccount:dev:dev-readonly-sa

no
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl auth can-i delete services -n dev --as=system:serviceaccount:dev:dev-readonly-sa
no
```

Blocking Lateral Movement between Namespaces

Networkpolicy allow

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl get svc -n dev
NAME           TYPE       CLUSTER-IP    EXTERNAL-IP   PORT(S)   AGE
nginx-service  ClusterIP  10.96.30.53   <none>        80/TCP    44m
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl exec -n prod test-client -- wget -qO- http://10.96.30.53
<!DOCTYPE html>
<html>
<head>
<title>Welcome to nginx!</title>
<style>
html { color-scheme: light dark; }
body { width: 35em; margin: 0 auto;
font-family: Tahoma, Verdana, Arial, sans-serif; }
</style>
</head>
<body>
<h1>Welcome to nginx!</h1>
<p>If you see this page, nginx is successfully installed and working.
Further configuration is required for the web server, reverse proxy,
API gateway, load balancer, content cache, or other features.</p>

<p>For online documentation and support please refer to
<a href="https://nginx.org/">nginx.org</a>.<br/>
To engage with the community please visit
<a href="https://community.nginx.org/">community.nginx.org</a>.<br/>
For enterprise grade support, professional services, additional
security features and capabilities please refer to
<a href="https://f5.com/nginx">f5.com/nginx</a>.</p>

<p><em>Thank you for using nginx.</em></p>
</body>
</html>
```

Networkpolicy deny

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl apply -f network-policy-deny.yaml
networkpolicy.networking.k8s.io/deny-from-prod created
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl get svc -n dev
NAME           TYPE       CLUSTER-IP    EXTERNAL-IP   PORT(S)   AGE
nginx-service  ClusterIP  10.96.30.53   <none>        80/TCP    47m
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl exec -n prod test-client -- wget -qO- http://10.96.30.53
```

PodSecurity Admission

k8s > ! privileged-pod.yaml

```yaml
apiVersion: v1
kind: Pod
metadata:
  name: privileged-test
  namespace: prod
spec:
  containers:
    - name: busybox
      image: busybox:latest
      command: ["sh", "-c", "sleep 3600"]
      securityContext:
        privileged: true
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS CODE REFERENCE LOG zsh - k8s

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl label namespace prod pod-security.kubernetes.io/enforce=baseline
namespace/prod not labeled
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s % kubectl apply -f privileged-pod.yaml
Error from server (Forbidden): error when creating "privileged-pod.yaml": pods "privileged-test" is forbidden: violates PodSecurity "baseline:latest": privileged (c
ontainer "busybox" must not set securityContext.privileged=true)
yuseoghyeon@yuseoghyeon-ui-MacBookAir k8s %
```

Trivy Scan 1

Build vul image

```
yuseoghyeon@yuseoghyeon-ui-MacBookAir docker % docker build -t vuln-app .
[+] Building 2.7s (8/8) FINISHED                                    docker:desktop-linux
 => [internal] load build definition from Dockerfile                                0.0s
 => => transferring dockerfile: 103B                                                0.0s
 => [internal] load metadata for docker.io/library/node:14                          2.6s
 => [internal] load .dockerignore                                                   0.0s
 => => transferring context: 2B                                                     0.0s
 => [1/3] FROM docker.io/library/node:14@sha256:a158d3b9b4e3fa813fa6c8c590b8f0a860e015ad4e59bbce5744d2f6fd8461aa   0.0s
 => => resolve docker.io/library/node:14@sha256:a158d3b9b4e3fa813fa6c8c590b8f0a860e015ad4e59bbce5744d2f6fd8461aa   0.0s
 => [internal] load build context                                                   0.0s
 => => transferring context: 27B                                                    0.0s
 => CACHED [2/3] WORKDIR /app                                                       0.0s
 => CACHED [3/3] COPY app.js .                                                      0.0s
 => exporting to image                                                              0.0s
 => => exporting layers                                                             0.0s
 => => exporting manifest sha256:b3af1296049bb9429e46c40778c05ddd668df458716c7f47a9d890cdca3d7c6e   0.0s
 => => exporting config sha256:850c012b0b9f91b7d2547a84fbffac9d6abee637e8a69a39bdd0081ae8bf941d   0.0s
 => => exporting attestation manifest sha256:be212ab8ff82fce2314a43a545c26aba17b8548b775b4a10f2e63d5985ef4bae   0.0s
 => => exporting manifest list sha256:b06b10d2863ff281e3fa9c4e3d915008b77d59abb3a6ecdb34982ac8fb74b425   0.0s
 => => naming to docker.io/library/vuln-app:latest                                  0.0s
 => => unpacking to docker.io/library/vuln-app:latest                               0.0s
yuseoghyeon@yuseoghyeon-ui-MacBookAir docker % docker images
                                                                  i Info →   U  In Use
IMAGE                                                   ID          DISK USAGE   CONTENT SIZE   EXTRA
kindest/node@sha256:452d707d4862f52530247495d180205e029056831160e22870e37e3f6c1ac31f   452d707d4862     1.31GB         363MB    U
vuln-app:latest                                         b06b10d2863f     1.28GB         340MB
yuseoghyeon@yuseoghyeon-ui-MacBookAir docker %
```

Trivy scan

```
Node.js (node-pkg)

Total: 19 (HIGH: 18, CRITICAL: 1)

┌──────────────────────────┬────────────────┬──────────┬────────┬───────────────┬──────────────────────────────────────────────────────────┐
│          Library         │ Vulnerability  │ Severity │ Status │ Installed Version │                      Fixed Version                       │
│                          │                │          │        │                   │                                                          │
│           Title          │                │          │        │                   │                                                          │
├──────────────────────────┼────────────────┼──────────┼────────┼───────────────┼──────────────────────────────────────────────────────────┤
│ ansi-regex (package.json)│ CVE-2021-3807  │ HIGH     │ fixed  │ 3.0.0         │ 6.0.1, 5.0.1, 4.1.1, 3.0.1                               │
│ nodejs-ansi-regex: Regular expression denial of service │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│ (ReDoS) matching ANSI escape codes │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│ https://avd.aquasec.com/nvd/cve-2021-3807 │                │          │        │               │                                                          │
│                          │                │          │        │               ├──────────────────────────────────────────────────────────┤
│                          │                │          │        │ 4.1.0         │                                                          │
│                          │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
├──────────────────────────┼────────────────┼──────────┼────────┼───────────────┼──────────────────────────────────────────────────────────┤
│ cross-spawn (package.json)│ CVE-2024-21538 │          │        │ 5.1.0         │ 7.0.5, 6.0.6                                             │
│ cross-spawn: regular expression denial of service │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│ https://avd.aquasec.com/nvd/cve-2024-21538 │                │          │        │               │                                                          │
├──────────────────────────┼────────────────┼──────────┼────────┼───────────────┼──────────────────────────────────────────────────────────┤
│ form-data (package.json) │ CVE-2025-7783  │ CRITICAL │        │ 2.3.3         │ 2.5.4, 3.0.4, 4.0.4                                      │
│ form-data: Unsafe random function in form-data │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│ https://avd.aquasec.com/nvd/cve-2025-7783 │                │          │        │               │                                                          │
├──────────────────────────┼────────────────┼──────────┼────────┼───────────────┼──────────────────────────────────────────────────────────┤
│ http-cache-semantics (package.json) │ CVE-2022-25881 │ HIGH     │        │ 3.8.1         │ 4.1.1                                                    │
│ http-cache-semantics: Regular Expression Denial of Service │                │          │        │               │                                                          │
│                          │                │          │        │               │                                                          │
│ (ReDoS) vulnerability    │                │          │        │               │                                                          │
```

Trivy Scan 2

Blocking github action(CI)

Summary

All jobs

trivy-scan

Run details

Usage

Workflow file

trivy-scan
failed 2 minutes ago in 38s

Search logs | Explain error

Run Trivy Scan 14s

```
"/home/runner/work/_temp/_runner_file_commands":"/github/file_commands" -v "/home/runner/work/Security-Automation-Project/Security-Automation-Project":"/github/workspace" fa8b6b:d1b11ee1b03c4974b4412b5bed1ae0c8  "-a image" "-b table" "-c " "-d 1" "-e true" "-f os,library" "-g HIGH,CRITICAL" "-h " "-i vuln-app" "-j ." "-k " "-l " "-m " "-n " "-o " "-p " "-q " "-r false" "-s " "-t " "-u " "-v " "-x " "-z " "-y "
Running trivy with options: trivy image  --format table --exit-code  1 --ignore-unfixed --vuln-type  os,library --severity HIGH,CRITICAL  vuln-app
Global options:
2026-03-18T20:38:09Z    INFO    Need to update DB
2026-03-18T20:38:09Z    INFO    Downloading DB...       repository="ghcr.io/aquasecurity/trivy-db:2"
65.42 MiB / 88.10 MiB [--------------------------------------------->_________________] 74.25% ? p/s ?88.10 MiB / 88.10 MiB [----------------------------------------------
```

Block Wildcard Permissions

Define dangerous role(*)

EXPLORER

SECURITY-AUTOMATION-PRO...
- .github/workflows
  - overprivileged-role.yaml
  - rbac.yml
  - terraform-deploy.yml
  - terraform-destroy.yml
  - terraform-validate.yml
  - trivy.yml
- aws-access-key-leak-det...
- kubernetes-security-auto...
  - ci
  - docker
  - k8s
    - .gitkeep
    - dev-readonly-role.yaml
    - dev-readonly-rolebindi...
    - dev-readonly-servicea...
    - namespace.yaml
    - network-policy-deny.ya...
    - nginx-deployment.yaml
    - nginx-service.yaml
    - overprivileged-role .yaml
    - overprivileged-role.yaml
    - privileged-pod.yaml
    - test-client.yaml
  - screenshots
  - threat-model
  - README.md
  - policy
  - check-rbac.sh

OUTLINE

TIMELINE

trivy.yml | overprivileged-role.yaml .../k8s | check-rbac.sh | overprivileged-role .yaml | rbac.yml | overprivileged-role.yaml .../workflows

kubernetes-security-automation-architecture > k8s > overprivileged-role .yaml

```yaml
apiVersion: rbac.authorization.k8s.io/v1
kind: Role
metadata:
  name: dangerous-role
  namespace: dev
rules:
- apiGroups: ["*"]
  resources: ["*"]
  verbs: ["*"]
```

PROBLEMS | OUTPUT | DEBUG CONSOLE | TERMINAL | PORTS | CODE REFERENCE LOG

```
on your username and hostname. Please check that they are accurate.
You can suppress this message by setting them explicitly. Run the
following command and follow the instructions in your editor to edit
your configuration file:

    git config --global --edit

After doing this, you may fix the identity used for this commit with:

    git commit --amend --reset-author

 2 files changed, 9 insertions(+)
 create mode 100644 kubernetes-security-automation-architecture/k8s/overprivileged-role .yaml
 create mode 100644 "kubernetes-security-automation-architecture/screenshots/\354\212\244\355\201\254\353\246\260\354\203\267 2026-03-19 \354\230\244\354\240\204 6
07.08.png"
yuseoghyeon@yuseoghyeon-ui-MacBookAir Security-Automation-Project % git push origin main
Enumerating objects: 11, done.
Counting objects: 100% (11/11), done.
Delta compression using up to 8 threads
Compressing objects: 100% (7/7), done.
Writing objects: 100% (7/7), 143.64 KiB | 14.36 MiB/s, done.
Total 7 (delta 4), reused 0 (delta 0), pack-reused 0 (from 0)
remote: Resolving deltas: 100% (4/4), completed with 4 local objects.
To https://github.com/bestminer12/Security-Automation-Project.git
```

Block github action(ci)

← RBAC Policy Check

add dangerous RBAC role for policy test #2

Re-run job

Summary

All jobs

rbac-policy-check

Run details

Usage

Workflow file

Annotations

1 error and 1 warning

rbac-policy-check

failed 1 minute ago in 3s

Search logs | Explain error

- Set up job
- Checkout
- Run RBAC Policy Check

```
1 ▸Run ./policy/check-rbac.sh
4 Scanning RBAC policies...
5 kubernetes-security-automation-architecture/k8s/overprivileged-role .yaml:  verbs: ["*"]
6 Over-privileged RBAC detected
7 Error: Process completed with exit code 1.
```

- Post Checkout
- Complete job

Response Strategy

- Automated detection of risky RBAC and vulnerable workloads
- Analyst-driven investigation with security context
- Context-based remediation and deployment control
- Reduces privilege abuse and operational security risk